2.6.2 Preventing XSS

So, how do you fix this? There are several steps that can be taken to avoid your API being used to launch XSS attacks against web browser clients:

- Be strict in what you accept. If your API consumes JSON input, then require that all requests include a `Content-Type` header set to `application/json`. This prevents the form submission tricks that you used in this example, as a HTML form cannot submit `application/json` content.
- Ensure all outputs are well-formed using a proper JSON library rather than by concatenating strings.
- Produce correct `Content-Type` headers on all your API's responses, and never assume the defaults are sensible. Check error responses in particular, as these are often configured to produce HTML by default.
- If you parse the `Accept` header to decide what kind of output to produce, never simply copy the value of that header into the response. Always explicitly specify the `Content-Type` that your API has produced.

Additionally, there are some standard security headers that you can add to all API responses to add additional protection for web browser clients:

Table 2.1 Useful security headers

Security header	Description	Comments
`X-XSS-Protection`	Tells the browser whether to block/ignore suspected XSS attacks.[5]	Set to "`1; mode=block`" on API responses. This tells the browser not to render the response at all if it detects a possible XSS. API responses should never be rendered directly in the first place, so blocking this is always the right thing to do.